

Atividade SAST/SCA/DAST - Criação de Relatório

Introdução

Esta atividade consiste na realização de scans utilizando ferramentas SAST e SCA, e exploração manual de vulnerabilidades utilizando uma ferramenta de DAST. Os resultados desses scans devem ser analisados para criar um relatório. O relatório deve, obrigatoriamente, possuir o nome do aluno e uma seção de apêndice no final contendo prints do terminal comprovando que os scans foram realizados.

Preparação

Para realizar as atividades, primeiro você deve baixar os arquivos “Avaliacao_Pratica_SAST_SCA.zip” e “Avaliacao_Pratica_DAST” disponibilizados, e extrair o seu conteúdo.

Para executar os ambientes, é necessário ter o docker instalado. Instruções de como os ambientes de cada ferramenta podem ser executados podem ser encontradas nos arquivos “Guia.pdf” e “Guia.md”. Os guias também contêm alguns comandos básicos das ferramentas a serem usadas.

O repositório alvo a ser utilizado para a Tarefa 1 (SAST) e Tarefa 2 (SCA) deve ser clonado na pasta “Avaliacao_Pratica_SAST_SCA/alvos/”. Ele pode ser encontrado em <https://github.com/NeuraLegion/broken crystals>. Para a Tarefa 3 (DAST) você deve se registrar na plataforma de CTF “Forge RSI” do grupo de pesquisa e extensão “Residência em Segurança da Informação - RSI” (<https://forge.rsiproject.org/>).

Tarefa 1 - Scan e Análise de Resultados do Semgrep

Para a primeira parte da Tarefa 1, você deverá fazer scan, utilizando a ferramenta semgrep, da pasta “broken crystals/src/” do repositório que foi clonado. Você saberá que fez scan da pasta correta se tiver como resultado 22 vulnerabilidades achadas. Além disso, o resultado do scan deve ser exportado para um arquivo json, podendo ser convertido para HTML se desejado.

Para a segunda parte, você deve escolher 2 vulnerabilidades com níveis de alerta “High” ou “Moderate” e Categorias Owasp Top 10 2025 diferentes. Tendo escolhido essas 2 vulnerabilidades com características diferentes, você irá realizar o seguinte procedimento para cada vulnerabilidade:

1. Estudar o CWE associado à esta vulnerabilidade;

2. Estudar a categoria OWASP Top 10 2025 associada à esta vulnerabilidade;
3. Calcular o vetor e score CVSS 4.0 da vulnerabilidade, utilizando a calculadora no link abaixo, usando apenas as métricas base (base metrics): <https://www.first.org/cvss/calculator/4.0>;
4. Sugerir um tempo de remediação baseado no nível de criticidade calculado;
5. Escrever no relatório uma explicação sobre a vulnerabilidade, levando em consideração os itens 1-4 acima.

Tarefa 2 - Scan e Análise de Resultados do OSV Scanner

Para a primeira parte da Tarefa 2, você deverá fazer um scan recursivo completo do repositório brokenocrystals que foi clonado, utilizando a ferramenta OSV Scanner. Você saberá que fez scan do repositório correto se tiver como resultado 242 vulnerabilidades achadas. Além disso, o resultado do scan deve ser exportado para um arquivo html.

Para a segunda parte, você deve escolher 2 CVEs, sendo eles de componentes vulneráveis diferentes e com níveis de severidade (Critical, High, Medium ou Low) diferentes. Tendo escolhido essas 2 vulnerabilidades com características diferentes, você irá realizar o seguinte procedimento para cada vulnerabilidade:

1. Buscar pelo CVE em algum banco de vulnerabilidades;
2. Ler o CVE e encontrar a categoria CWE dele (deve estar presente no próprio banco de vulnerabilidades);
3. Classificar o CVE com base em uma das categorias do OWASP TOP 10 2025 (observação: nem toda categoria do CWE mapeia diretamente para uma categoria do OWASP Top 10 2025. Nesse caso, analise cuidadosamente em qual categoria melhor se encaixaria);
4. Verificar se existe alguma sugestão oficial de remediação para a vulnerabilidade além da atualização do componente. Se não tiver, sugerir uma remediação com base em alguma técnica de mitigação para o CWE da vulnerabilidade;
5. Com base nos score de CVSS e entendimento da vulnerabilidade, sugerir um tempo de remediação para a vulnerabilidade;
6. Escrever no relatório uma explicação sobre a vulnerabilidade, levando em consideração os itens 1-5 acima.

Tarefa 3 - Exploração Manual de Vulnerabilidades Utilizado o Burp Suite

Você deve escolher e resolver um desafio da categoria Web da plataforma de CTF “Forge RSI” com o auxílio da ferramenta Burp Suite. Após a resolução do desafio, explicar no relatório o passo-a-passo da resolução com prints da sua tela.

Entregável

Um arquivo .zip contendo o relatório em formato .pdf e os resultados dos scans SAST e SCA exportados para arquivos .html.